

# SOC 2 TYPE II READINESS AUDIT

## IT General Controls Report

### **Meridian Health Partners**

*Audit Period: January 1, 2026 – June 30, 2026*

Prepared by

**Carla Bee**

GRC / IT Audit Practice — CMB Enterprise Group LLC

Report Date: July 1, 2026

*CONFIDENTIAL — Portfolio / Demonstration Document. Meridian Health Partners is a fictitious entity used for illustrative purposes only.*

## 1. Executive Summary

---

CMB Enterprise Group LLC performed a SOC 2 Type II readiness audit of Meridian Health Partners' information technology general controls (ITGC) covering the period January 1, 2026 through June 30, 2026. The engagement evaluated the design and operating effectiveness of controls mapped to the AICPA Trust Services Criteria (TSC) for Security (the Common Criteria), Availability, and Confidentiality.

Of 22 controls tested across 11 TSC categories, 17 controls operated effectively, 5 controls operated with a noted exception, and no controls failed outright. The exceptions did not indicate a pervasive breakdown in the control environment; each was isolated, had a compensating factor, and management agreed to remediation actions with target dates within this fiscal year. Overall, Meridian's control environment is assessed as reasonably well-designed and largely operating effectively, with targeted improvements needed in termination-access timeliness, vulnerability remediation SLA governance, vendor attestation tracking, risk register documentation, and disaster recovery runbook automation.

This report is intended to support Meridian's readiness for a formal SOC 2 Type II examination by an independent CPA firm and to give management a prioritized remediation roadmap in advance of that engagement.

## 2. Audit Scope & Objectives

---

The scope of this engagement included the information systems, infrastructure, and supporting business processes that underpin Meridian Health Partners' patient scheduling and claims-processing platform, which stores and transmits protected health information (PHI). The objectives of the audit were to:

- Evaluate whether ITGCs are suitably designed to meet the AICPA Trust Services Criteria for Security, Availability, and Confidentiality;
- Test the operating effectiveness of a risk-based sample of those controls over the audit period;
- Identify control gaps or exceptions and assess their risk to the confidentiality, integrity, and availability of in-scope systems and data;
- Provide management with actionable, time-bound remediation recommendations ahead of a formal SOC 2 Type II examination.

This engagement was performed as an internal readiness assessment and does not constitute an official SOC 2 report issued under AICPA attestation standards. It is intended to identify and remediate gaps prior to engaging an independent service auditor.

## 3. Methodology

---

Testing was performed using a combination of inquiry, observation, inspection of evidence, and re-performance, consistent with common IT audit practice and mapped to NIST SP 800-53 Rev. 5 control families for cross-reference. For each control, a risk-based sample was selected — full population for low-volume controls (e.g., annual DR test) and statistical or judgmental sampling for higher-volume, transaction-level controls (e.g., access provisioning, change tickets).

Evidence reviewed included system-generated reports and logs, policy and procedure documentation, meeting minutes, ticketing system records, access control matrices, and configuration exports. Testing was performed in accordance with generally accepted IT audit practices and the control-testing conventions used by SOC 2 service auditors.

### Control Rating Definitions

- Pass — the control operated effectively for the full sample with no exceptions noted.
- Pass with Exception — the control is designed effectively and generally operating, but testing identified one or more instances of non-adherence that do not rise to the level of a full control failure.
- Fail — the control did not operate as designed, or a majority of the sample did not conform to the control objective.

## 4. System Description

Meridian Health Partners ("Meridian") operates a cloud-hosted patient scheduling and claims-processing platform used by mid-size healthcare provider groups. The environment is hosted on a major public cloud provider, uses Azure AD for identity and access management, and processes protected health information (PHI) subject to HIPAA as well as payment-card data subject to PCI DSS for co-pay collection. Key infrastructure components in scope included:

- Production application and database tier hosting the scheduling and claims-processing platform
- Identity and access management (Azure AD, Conditional Access, MFA)
- Endpoint detection and response (EDR) and SIEM logging/monitoring
- Change management and CI/CD deployment pipeline
- Backup, disaster recovery, and business continuity infrastructure
- Third-party vendor ecosystem supporting claims clearinghouse and payment processing

## 5. Summary of Results

The table below summarizes testing results by Trust Services Category. Full control-level detail, test procedures, and evidence references are maintained in the companion Controls Testing Workbook.

| Trust Services Category           | # Controls Tested | Result Summary      | Exceptions |
|-----------------------------------|-------------------|---------------------|------------|
| CC1 – Control Environment         | 2                 | 2 Pass              | 0          |
| CC2 – Communication & Information | 1                 | 1 Pass              | 0          |
| CC3 – Risk Assessment             | 1                 | 1 Pass w/ Exception | 1          |
| CC4 – Monitoring Activities       | 1                 | 1 Pass              | 0          |
| CC5 – Control Activities          | 1                 | 1 Pass              | 0          |

| Trust Services Category         | # Controls Tested | Result Summary              | Exceptions |
|---------------------------------|-------------------|-----------------------------|------------|
| CC6 – Logical & Physical Access | 6                 | 5 Pass, 1 Pass w/ Exception | 1          |
| CC7 – System Operations         | 3                 | 2 Pass, 1 Pass w/ Exception | 1          |
| CC8 – Change Management         | 1                 | 1 Pass                      | 0          |
| CC9 – Risk Mitigation (Vendor)  | 1                 | 1 Pass w/ Exception         | 1          |
| A1 – Availability               | 3                 | 2 Pass, 1 Pass w/ Exception | 1          |
| C1 – Confidentiality            | 2                 | 2 Pass                      | 0          |

22 controls were tested in total: 17 passed with no exceptions and 5 passed with a noted exception. No controls were rated as a full failure. Detailed findings for each exception are presented in Section 6.

## 6. Detailed Findings

Five exceptions were identified during testing. Each finding below includes the affected control, a risk rating based on likelihood and impact, the condition observed, CMB's recommendation, and management's response and remediation commitment.

| ID   | Control | Risk   | Finding                                                                                                                      | Recommendation                                                                                                                                                                | Mgmt Response                                                                           |
|------|---------|--------|------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| F-01 | CC3.1   | Medium | Risk register entries lack a documented owner and re-assessment date for medium-rated risks.                                 | Update risk register template to require an owner and next review date on every open risk; backfill existing medium/high risks within 30 days.                                | Agreed. Compliance to update template by 8/15/2026.                                     |
| F-02 | CC6.2   | Medium | 2 of 15 terminations tested had access disabled 26–31 hours after termination, exceeding the 24-hour SLA.                    | Implement a real-time HR-to-IAM termination trigger to replace the nightly batch job; add automated SLA-breach escalation.                                                    | Agreed. Interim manual escalation is active; engineering scoping real-time integration. |
| F-03 | CC7.1   | High   | 1 of 10 critical vulnerabilities tested was remediated in 42 days (SLA: 30 days) with no documented risk acceptance on file. | Require documented risk acceptance with a compensating control for any critical finding projected to exceed SLA; escalate vendor-dependent patches within 5 days of SLA risk. | Agreed. Procedure update targeted for 8/31/2026.                                        |
| F-04 | CC9.1   | Medium | SOC 2 reports on file for 2 of 8 critical vendors were more than 15 months old at the time of testing.                       | Implement a vendor risk tracker with automated 90-day expiration reminders; request current reports from the 2                                                                | Agreed. Tracker build in GRC tool targeted for 9/15/2026.                               |

| ID   | Control | Risk   | Finding                                                                                                                                       | Recommendation                                                                                        | Mgmt Response                                                 |
|------|---------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
|      |         |        |                                                                                                                                               | affected vendors.                                                                                     |                                                               |
| F-05 | A1.3    | Medium | FY2026 DR test met RTO for 4 of 5 in-scope systems; the claims-processing system exceeded target RTO by 3 hours due to manual failover steps. | Update and automate the claims-processing failover runbook; retest at the next scheduled DR exercise. | Agreed. Runbook update by 9/1/2026, validation at Q4 DR test. |

One finding (F-03, critical vulnerability remediation SLA) was rated High risk due to the combination of a critical-severity vulnerability, an unremediated exposure window beyond policy SLA, and the absence of a documented compensating control or risk acceptance. The remaining four findings were rated Medium risk, reflecting isolated instances with existing partial mitigations.

## 7. Overall Conclusion & Opinion

Based on the procedures performed, CMB Enterprise Group LLC concludes that Meridian Health Partners' IT general controls are suitably designed to meet the Security, Availability, and Confidentiality Trust Services Criteria, and were operating effectively for the majority of controls tested during the audit period. The five exceptions identified represent isolated, remediable gaps rather than pervasive control deficiencies, and management has committed to remediation with defined owners and target dates.

CMB recommends Meridian address Finding F-03 (critical vulnerability SLA governance) as the highest priority given its risk rating, followed by the remaining Medium-risk findings, prior to engaging an independent CPA firm for a formal SOC 2 Type II examination. A follow-up readiness check is recommended approximately 90 days after this report to confirm remediation status before the formal examination period begins.

## 8. Appendix A — Controls Tested

A complete list of the 22 controls tested, including control descriptions, test procedures, sample sizes, and evidence references, is maintained in the companion workbook: SOC2\_ITGC\_Controls\_Testing\_Workbook.xlsx (tabs: Controls Matrix, Risk & Findings Log, Summary Dashboard).

## 9. Report Distribution & Confidentiality

This report and its contents are confidential and intended solely for the use of Meridian Health Partners management and its Audit & Compliance Committee. It should not be distributed outside the organization without written consent from CMB Enterprise Group LLC.

**Prepared by: Carla Bee, GRC/IT Audit Practice — CMB Enterprise Group LLC**

*Note: Meridian Health Partners is a fictitious company created for portfolio and demonstration purposes. This report illustrates the structure, methodology, and deliverables of a SOC 2 ITGC audit engagement.*